

Axiom Nexus, LLC — Information Security Policy

Effective date: April 23, 2026**Owner:** Clarence Fuqua, Founder, Axiom Nexus, LLC**Contact:** security@axiomprotocol.app (monitored group address) · info@axiomprotocol.app (general)**Review cadence:** Annually, or upon any material change to the data scope, third-party processor list, or applicable law.**Status:** Canonical. This document is the source of truth for the Axiom Nexus information security program.

This policy is rendered verbatim at `/disclosure/information-security-policy`. The file at `documents/policies/information-security-policy.md` is the canonical text. Any change to the policy must change this file; the disclosure page reads it at request time so the document and the page can never drift.

1. Purpose and scope

This policy defines the controls that Axiom Nexus, LLC ("Axiom Nexus", "we") applies to identify, mitigate, and monitor information security risks across the Axiom Protocol platform ("the Platform").

It applies to:

- All production systems that store, process, or transmit consumer financial data, including wallet identifiers, banking credentials, account and routing numbers, transaction history, and account balances obtained through Plaid, Increase, BitGo, or any other regulated rail.
- All non-production systems (development, staging) that handle data derived from production sources.
- All employees, contractors, and service providers ("personnel") who hold access to any of the above.
- All software, infrastructure, and third-party services used to operate the Platform.

The policy is operationalised through (a) the controls enumerated in this document, (b) the append-only audit-event log (`cap_audit_events`), (c) code review on every change merged to the main branch, (d) automated dependency vulnerability scanning, and (e) periodic access reviews.

2. Roles and responsibilities

Role	Holder	Responsibility
Information Security Lead	Clarence Fuqua	Owns this policy, approves exceptions, signs off on third-party processors, and is the primary point of contact for security disclosures.
Engineering	All contributors with write access to the Axiom Protocol repository	Implement controls in code, follow the secure development practices in §7, escalate suspected incidents within 4 hours of detection.
Operators	Personnel with operator role access	Follow least-privilege principles, complete access reviews, never share credentials, never store secrets outside the secret management system.

Third-party processors	Plaid, Increase, Neon, Replit, BitGo, Resend, Auth0, GitHub, Alchemy, and other vendors enumerated in <code>replit.md</code>	Bound by their own published security commitments and by contractual terms; Axiom Nexus performs initial diligence and re-evaluates annually.
------------------------	--	---

3. Data classification

Data handled by the Platform is classified into three tiers:

- **Restricted.** Plaid `access_token`, Plaid `item_id`, banking account and routing numbers, government identifiers, private keys, OAuth refresh tokens, signed legal documents. Access is limited to the minimum personnel and processes required and is logged on every read.
- **Confidential.** Wallet addresses, transaction history, account balances, audit events, internal financial reports. Access is role-restricted; bulk exports are logged.
- **Public.** Marketing copy, published disclosures, on-chain data, the contents of the Axiom Protocol white paper.

Restricted data is never transmitted via email, chat, or any unencrypted channel. Restricted data is never copied to a developer machine; it is only ever read in production by server-side code that needs it for the immediate request.

4. Identity and access management

- **Multi-factor authentication (MFA)** is required for every system that stores or processes Restricted or Confidential data. This is enforced today on Replit, Neon Postgres, Increase Dashboard, Plaid Dashboard, BitGo Dashboard, Auth0 Dashboard, and GitHub. Personnel without MFA on a covered system have their access revoked.
- **End-user authentication** is performed via Sign-In With Ethereum (SIWE) backed by a self-custodied wallet, supplemented by Auth0 sessions for operator surfaces. Plaid Link is only surfaced to a user who has already established an authenticated session.
- **Role-based access control (RBAC)** is enforced at the API layer. Users, operators, and administrators see disjoint surfaces. The policy evaluator (`lib/capinfra/policy`) gates every state-changing financial action against a versioned, deterministic policy.
- **Principle of least privilege.** Production database credentials are scoped to the schemas the application requires. Personal access tokens are short-lived. Long-lived shared credentials are prohibited.
- **Periodic access reviews** are conducted quarterly by the Information Security Lead. The review covers every personnel-bound credential on every covered system and every non-human credential (API keys, OAuth client credentials, service-account tokens, signed-JWT issuers).
- **Automated de-provisioning on termination or role change.** When a contributor leaves or moves off the production-data path, their credentials are revoked within five business days through the centralised access list maintained by the Information Security Lead. Production-system access is single-sourced through MFA-protected dashboards so revocation in those dashboards is sufficient to terminate access.
- **Non-human authentication.** Service-to-service calls authenticate using short-lived OAuth tokens or signed JWTs delivered over TLS 1.2+. Inbound webhook traffic from regulated processors is verified by signature (Stripe-style HMAC, Plaid `Plaid-Verification` JWT, Increase-style headers) before any side effect is taken. Long-lived shared API keys are prohibited where the underlying system supports OAuth or signed-JWT alternatives, and where they are unavoidable they are scoped to a single function and rotated.
- **Zero-trust access architecture.** No request is trusted by virtue of network position. Every request to a Restricted-data endpoint is authenticated, authorised against the policy evaluator (`lib/capinfra/policy`), and audited regardless of whether it originated inside the production runtime, from the operator console, or from a third-party processor webhook. There is no internal "trusted network" that bypasses these checks.

- **Audit logging.** Every privileged action against Restricted or Confidential data is recorded in the append-only `cap_audit_events` table with the actor, the subject, the timestamp, the correlation identifier, and the policy decision identifier where applicable. Audit events are retained for seven years.

5. Infrastructure and network security

- **Encryption in transit.** All client-server traffic terminates on TLS 1.2 or higher. The Platform is hosted on Replit Autoscale, which provides managed TLS certificates and enforces TLS 1.2+ on all inbound HTTPS traffic. The internal preview proxy uses mutual TLS. All outbound calls to Plaid, Increase, Neon Postgres, BitGo, Alchemy, and other third-party APIs are made over TLS 1.2+.
- **Encryption at rest.** Production data is stored in Neon-hosted Postgres, which encrypts all data at rest using AES-256. Analytics data is stored in MongoDB Atlas, also AES-256 at rest. Object storage is encrypted at rest by the underlying provider (Google Cloud Storage, Storacha/IPFS as applicable).
- **Secrets management.** All production credentials, API keys, signing secrets, deployer keys, and webhook secrets are stored in the Replit-managed secret store and injected into the runtime as environment variables. Plaintext secrets are never present in source control, deploy artifacts, log output, error messages, or any user-facing response. Pre-commit and code-review controls prevent accidental commit of secret material.
- **Application-layer protection of high-sensitivity tokens.** Plaid `access_token` values, in addition to database-level encryption at rest, are envelope-encrypted at the application layer using a key derived from the secret store and rotated on a defined schedule. They are never logged, never returned in API responses, never written to error messages, and never exposed to the browser.
- **Network segmentation.** Production credentials are not present in non-production environments. Non-production environments do not have read or write access to production data stores.
- **Hardened runtime.** The production runtime is an immutable container managed by Replit Autoscale. Personnel do not have shell access to running production instances. Configuration changes flow through source control.

6. Third-party risk management

Before a new processor is added to the Restricted or Confidential data path, Axiom Nexus reviews the processor's published security posture (SOC 2, ISO 27001, or equivalent), data processing terms, breach-notification commitments, and sub-processor list. The processor is added to the inventory in `replit.md` and is reviewed annually against the same criteria. A processor that materially weakens its security posture is removed.

Current processors with access to Restricted or Confidential data:

- **Plaid** — bank account verification (Auth) and balance inquiry (Balance).
- **Increase** — primary banking rail; ACH, wire, and account services.
- **Neon** — managed Postgres for production data.
- **Replit** — application hosting, secret storage, deployment platform.
- **BitGo** — institutional crypto custody.
- **Auth0** — operator-side identity provider.
- **GitHub** — source control.
- **Alchemy** — Ethereum/Arbitrum RPC provider; reads only public on-chain data.
- **Resend** — transactional email; receives email addresses and message contents only.

7. Secure development and vulnerability management

- **Code review.** Every change to the production codebase is reviewed before merge. Changes that touch authentication, payments, secret handling, or external API integrations receive a deeper security-focused review.
- **Automated dependency scanning.** Dependency vulnerabilities are surfaced on every commit and on a continuous schedule. Critical and high-severity findings are remediated within seven days; medium-severity within thirty days.
- **Static application security testing.** The codebase is scanned for common vulnerability classes (injection, broken access control, insecure direct object reference, hard-coded secrets) on a continuous schedule.
- **Endpoint security on contributor machines.** Contributors operate on machines with full-disk encryption, automatic OS patching, automatic screen lock, and an actively maintained antivirus or endpoint detection solution. Contractors who require access to Restricted data are required to operate on managed devices.
- **No persistent contributor access to production hosts.** The production runtime is ephemeral; deploys are immutable from source. Centralised secret management eliminates long-lived credentials on developer machines.
- **Continuous integration controls.** Build pipelines enforce that test, type-check, and lint stages pass before any merge. Smoke harness coverage (`npm run test:capinfra-smoke`) exercises the capital-infrastructure path end-to-end on every release.
- **End-of-life software monitoring.** The runtime, language version (Node.js LTS), and material direct dependencies are tracked against their published support lifecycles. A package or runtime that has reached or is within ninety days of end-of-life triggers a remediation ticket owned by the Information Security Lead; an end-of-life dependency on the Restricted-data path is treated as a critical-severity finding subject to the seven-day remediation SLA.

8. Privacy and data subject rights

- A published privacy policy at `/privacy` describes the categories of data collected, the purposes of processing, the third-party processors involved, the retention periods, and the user's rights of access and deletion.
- Consent for the collection, processing, and storage of consumer data is obtained explicitly before Plaid Link is surfaced. The consent text version, the timestamp, and the user identifier are recorded as an audit event.
- Data subject requests (access, deletion, correction) are processed within thirty days. Plaid-derived data is removed from the active store via Plaid `/item/remove` and a corresponding row deletion within thirty days of the qualifying event.
- Records required by the Bank Secrecy Act and other applicable financial-records laws are retained for the legally required period (typically five years) in masked form on the audit trail.

9. Incident response

- **Detection.** Anomalies are surfaced through (a) automated monitoring of error rates and webhook reconciliation drift, (b) the runtime integrity checks built into the capital-infrastructure layer (`collateral.integrity_failed` audit events), and (c) reports from personnel, users, or third parties received at security@axiomprotocol.app (monitored group address).
- **Triage.** A suspected incident is escalated to the Information Security Lead within four hours of detection.
- **Containment.** Affected credentials are rotated. Affected accounts have access suspended. The emergency-disable controls on the Increase adapter and the guardian-disable path on capital infrastructure may be invoked to halt rail movement.
- **Investigation.** The Information Security Lead reconstructs the event timeline from `cap_audit_events`, application logs, and processor-side logs.
- **Notification.** If a confirmed incident materially affects consumer financial data, affected users are notified, Plaid is notified within seventy-two hours, and any other regulator or processor with a contractual or legal notification right is notified within the required window.

- **Remediation and post-mortem.** A remediation plan is published internally; controls are added or strengthened to prevent recurrence; the post-mortem is appended to the incident register.

10. Business continuity

- Source code and infrastructure-as-code are version-controlled and mirrored on GitHub.
- Production data is backed up by Neon according to its published backup posture; backups are encrypted at rest and Axiom Nexus periodically validates point-in-time recovery.
- The Platform runtime is hosted on managed infrastructure that supports automatic recovery from instance failure.

11. Policy review and exceptions

This policy is reviewed at least annually by the Information Security Lead. Changes are recorded by editing this file in source control; the rendered disclosure page at `/disclosure/information-security-policy` reflects the current text on every load.

Exceptions to this policy may only be granted in writing by the Information Security Lead and must be time-bound and accompanied by a compensating control.

Axiom Nexus, LLC operates the Axiom Protocol platform. Security disclosures should be sent to security@axiomprotocol.app (monitored group address). General questions and access requests may be sent to info@axiomprotocol.app.